

ROCKLEDGE BENEFITS ADMINISTRATORS — AI SYSTEM INVENTORY & RISK CLASSIFICATION

Sample GRC portfolio artifact | Fictional company | Framework basis: NIST AI RMF 1.0 (Map), EU AI Act as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI, in force 27 July 2026), ISO/IEC 42001 A.4 | Inventory date: 2026-08-05

AI ID	System Name	Business Owner	Use Case	Deployment Status	AI Type	Provider / Model	Build vs Buy	Data Inputs	Personal Data?	Decision Impact	Human Oversight Mode	EU Nexus?	EU AI Act Tier (legal)	Applicable Deadline	EU Act Rationale	Organizational Risk Flag	NIST AI RMF Profile Applied	Inherent Risk (1-5)	Governance Status	Next Action
AI-001	ClaimDesk Adjudication Assist	VP Claims Operations	Recommends approve/deny/pend on benefits claims; adjuster confirms	Production	Predictive ML (gradient boosting)	In-house model on Azure ML	Build	Claim history, plan rules, provider codes, member demographics	Yes	Determines member benefit outcomes	Human-in-the-loop (adjuster confirms each)	Yes — 3 EU-based client plans	High-Risk (contested)	2 Dec 2027 if confirmed	CONTESTED. Annex III(5)(a) covers essential PUBLIC assistance benefits by public authorities — Rockledge is a private administrator. Annex III(5)(c) covers risk assessment and pricing for life/health insurance — this is claims adjudication, not pricing. Neither category fits cleanly. Treated as high-risk pending counsel determination; see Risk AIR-004 for both classification outcomes.	—	AI RMF Core + fairness testing profile	5	Ungoverned	Priority 1: obtain counsel determination on Annex III applicability; proceed with fairness testing regardless (see Decision Memo)
AI-002	Member Support Chatbot	Director of Member Services	Answers plan questions, routes to agents; GenAI over plan documents	Production	Generative (LLM, RAG)	Azure OpenAI GPT-4o over indexed plan docs	Buy + configure	Member questions, plan documents, limited account context	Yes	Informational; can misdirect on coverage	Human-on-the-loop (escalation available)	Yes	Limited-Risk (transparency)	2 Aug 2026 — NOT DEFERRED	Art. 50 transparency duties apply to systems interacting with natural persons. The Digital Omnibus deferred Annex III high-risk deadlines but expressly did NOT defer Art. 50. This is the most time-critical item in the inventory.	—	AI RMF Core + Generative AI Profile (AI 600-1)	4	Partially governed	Deploy AI disclosure immediately (deadline passed); implement conabulation testing; log and sample coverage answers
AI-003	Fraud Pattern Detector	Director of SIU	Flags claims for special investigation review	Production	Predictive ML (anomaly)	Third-party SaaS (VigilAI)	Buy	Claims data, provider billing patterns	Yes	Triggers investigation; may delay payment	Human-on-the-loop	No	Out of EU scope	N/A	No EU nexus. If scope expands to EU plans, re-assess against Annex III.	—	AI RMF Core	3	Partially governed	Vendor AI questionnaire; document oversight; re-assess on any EU expansion
AI-004	Recruiting Resume Screener	VP People	Ranks applicants for benefits-analyst roles	Pilot	Predictive ML (NLP scoring)	Third-party ATS module	Buy	Resumes, application forms	Yes	Affects hiring shortlist	Human-in-the-loop (recruiter reviews top 20)	Yes — EU-based recruiting for Dublin office	High-Risk	2 Dec 2027	CLEAR. Annex III(4)(a) — AI intended for recruitment or selection, in particular to filter applications and evaluate candidates. Unambiguous. Also NYC Local Law 144 exposure for NYC roles, which has no EU deadline dependency.	—	AI RMF Core + fairness testing profile	5	Ungoverned	Priority 1: pause pilot pending bias audit and vendor transparency documentation (see Decision Memo)
AI-005	Document Intake OCR	Director of Operations	Extracts fields from submitted forms	Production	Computer vision / OCR	Azure Document Intelligence	Buy	Scanned forms, member IDs	Yes	Data entry accuracy	Human-on-the-loop (exception queue)	Yes	Minimal	N/A	Data extraction with human exception handling; no consequential decision.	—	AI RMF Core (light)	2	Governed	Annual accuracy validation; keep in inventory
AI-006	Marketing Content Generator	Director of Marketing	Drafts campaign copy and member communications	Production	Generative (LLM)	ChatGPT Enterprise	Buy	Marketing briefs, brand guidelines	No	Low; human edits all output	Human-in-the-loop	No	Minimal	N/A	No personal data; all output human-reviewed before publication. Note Art. 50(4) synthetic-content marking may apply if AI-generated imagery is published.	—	Generative AI Profile (light)	2	Governed	Acceptable use attestation; monitor for synthetic-media marking obligations
AI-007	Analyst Copilot (M365)	CIO	Summarizes documents, drafts emails across the workforce	Production	Generative (LLM)	Microsoft 365 Copilot	Buy	Enterprise email, files, chats — potentially PHI/PII	Yes	Productivity; data exposure risk	Human-in-the-loop	Yes	Minimal	N/A	Not a high-risk use case under the Act. The exposure here is data governance, not AI Act classification — tracked separately in the Organizational Risk Flag column.	HIGH — broad access to PHI repositories creates HIPAA exposure independent of AI Act status	Generative AI Profile — data privacy & information integrity	3	Partially governed	Restrict Copilot indexing of PHI repositories; DLP for AI-generated content; usage attestation
AI-008	Actuarial Forecast Model	Chief Actuary	Projects claims cost for pricing	Production	Statistical / ML hybrid	In-house (R + Python)	Build	Historical claims, demographic aggregates	No (aggregated)	Pricing decisions; indirect member impact	Human-in-the-loop	No	Minimal	N/A	Aggregate data, expert-reviewed outputs. NOTE: if this model were applied to individual health-insurance risk assessment or pricing, Annex III(5)(c) would apply. It is not, today.	—	AI RMF Core + model risk management	3	Governed	Annual model validation; re-assess if scope moves to individual pricing
AI-009	Shadow AI (governance finding)	CISO (owner by default)	Unsanctioned consumer AI tool use with work data	Not a system — enterprise finding	Generative (various)	Consumer ChatGPT, Gemini, Claude free tiers	Unmanaged	Unknown; likely includes member data	Likely	Data leakage; policy violation	None	Unknown	N/A — governance finding	N/A	Not an AI system and therefore not classifiable under the Act. Recorded here because an inventory that omits known unmanaged use is not an inventory. Discovered via CASB telemetry: 214 unique users hitting consumer AI endpoints in 30 days.	CRITICAL — uncontrolled PHI egress to third-party models with no DPA or contractual protection	AI RMF Govern function	4	Ungoverned	Acceptable use policy; CASB blocking; sanctioned alternative (AI-007); awareness campaign

INVENTORY SUMMARY

Eight identified AI systems plus one enterprise shadow-AI go

EU AI Act Tier	Count
High-Risk	1
High-Risk (contested)	1
Limited-Risk (transparency)	1
Minimal	4
Out of EU scope	1
N/A — governance finding	1

Governance Status	Count
Ungoverned	3
Partially governed	3
Governed	3

Entries flagged for personal data	6
Systems with EU nexus	5
High-Risk (incl. contested) AND Ungove	2

HOW SYSTEMS WERE CLASSIFIED

Why an inventory first	You cannot govern what you have not enumerated. Every AI governance framework — NIST AI RMF (Map 1), ISO/IEC 42001 (A.4 resources), EU AI Act (registration obligations) — presumes an inventory exists. Most organizations do not have one; discovery via procurement records, cloud consoles, and CASB telemetry is the first real task.
Discovery sources used	(1) Procurement and SaaS spend records, (2) Azure/M365 admin consoles, (3) CASB / web proxy telemetry for AI endpoints, (4) Interviews with department heads, (5) Engineering repository scan for ML dependencies. AI-009 (shadow AI) surfaced only through source 3.
EU AI Act tiers	Unacceptable (prohibited) → High-Risk (Annex III categories incl. employment, essential private services, credit) → Limited (transparency duties, e.g. chatbots) → Minimal. Classification depends on use case and context, not on the technology. The same LLM is Minimal in marketing and Limited in a member-facing chatbot.
Human oversight modes	In-the-loop = a person confirms each output before it takes effect. On-the-loop = system acts, person monitors and can intervene. Out-of-the-loop = fully automated. Under the EU AI Act, human oversight (Art. 14) is a required control for high-risk systems, not a classification-reducing factor by itself.
Inherent risk (1-5)	Composite of decision impact, personal data sensitivity, autonomy, and population affected. Ordinal, for prioritization only — see the Risk Assessment artifact for the fuller treatment.
Timeline caveat	EU AI Act high-risk obligations were originally applicable 2 August 2026. A May 2026 'Digital Omnibus' proposal would defer standalone high-risk systems to 2 December 2027. As of this inventory that deferral is proposed, not adopted. Plans here assume the earlier date until the text is final — planning to the later date and being wrong is the costlier error.
What this is not	This is a portfolio artifact for a fictional company. It is not legal advice on EU AI Act applicability. Real classification of a high-risk system requires counsel and, for many Annex III categories, a documented conformity assessment.